# Action plan

**Domain** Care Access Navigator - IAM & GRC
**Perimeter** Mock EHR - Workforce Access Governance
**Assessment** Healthcare IAM - HIPAA Security Rule Access Controls Audit — 2.0
**Framework** NIST - NIST SP-800-66 rev2 (HIPAA)

Associated applied controls, separated by status and sorted by ETA. 18 in total.

**To do (1)**

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| Security logs are kept 12 months | Security logs are kept 12 months<br><br>Area: Monitoring / retention<br>HIPAA: 164.316(b)(2) (policy); 164.312(b)<br>NIST CSF 2.0: PR.PS-04<br>NIST SP 800-53 r5: AU-11<br>ISO 27001:2022: A.8.15<br>PCI DSS 4.0.1: 10.5.1<br>Risks: R03<br>Evidence: Compliance E-LOG-01<br>Test: Audit LOG-01 test 3<br>Test result (2026-11-03): FAIL | Technical | akchrao@gmail.com | - | 2. Retain Documentation for at Least Six Years |

**In progress (5)**

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| ePHI and credentials are encrypted in transit (TLS 1.2+) | ePHI and credentials are encrypted in transit (TLS 1.2+)<br><br>Area: Data protection<br>HIPAA: 164.312(e)(1), (e)(2)(ii)<br>NIST CSF 2.0: PR.DS-02<br>NIST SP 800-53 r5: SC-8, SC-8(1)<br>ISO 27001:2022: A.8.24<br>PCI DSS 4.0.1: 4.2.1<br>Risks: R03<br>Evidence: Compliance E-ENC-01<br>Test: Audit ENC-01 tests 1-4<br>Test result (2026-11-03): PASS (Azure); EXCEPTION (IdP) | Technical | akchrao@gmail.com | - | 4. Implement Encryption |
| Privileged and cardholder-data users pass MFA | Privileged and cardholder-data users pass MFA<br><br>Area: Authentication | Technical | akchrao@gmail.com | - | 3. Select and Implement Authentication Options |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | HIPAA: 164.312(d)<br>NIST CSF 2.0: PR.AA-03<br>NIST SP 800-53 r5: IA-2(1), IA-2(2)<br>ISO 27001:2022: A.8.5<br>PCI DSS 4.0.1: 8.4.1, 8.4.2<br>Risks: R03<br>Evidence: EV-13 verify (MFA_REQUIRED)<br>Test: W5 verify; TC-03<br>Test result (2026-11-03): PASS | | | | |
| Privileged access is approved, limited and monitored | Privileged access is approved, limited and monitored<br><br>Area: IAM / PAM<br>HIPAA: 164.308(a)(4)(ii)(B)<br>NIST CSF 2.0: PR.AA-05<br>NIST SP 800-53 r5: AC-2(7), AC-6(5), AC-6(9)<br>ISO 27001:2022: A.8.2<br>PCI DSS 4.0.1: 7.2.2, 8.2.2<br>Risks: R04<br>Evidence: Privileged access matrix; TC-07<br>Test: TC-07<br>Test result (2026-11-03): PASS | Technical | akchrao@gmail.com | - | 2. Implement Policies and Procedures for Authorizing Access<br>7. Establish an Emergency Access Procedure |
| Automated Keycloak Leaver Deprovisioning | Implement automated deprovisioning between Microsoft Entra ID and Keycloak so that workforce termination triggers the timely disablement of corresponding Keycloak accounts, revocation of active sessions, and verification of application access removal.<br><br>Implement reconciliation and alerting to detect accounts that remain enabled after termination.<br><br>This planned control addresses the deprovisioning gap identified during Jeevan Smith's termination (TERM-2026-0301).<br><br>Implementation and effectiveness testing are pending.<br><br>Remediation Validation Plan – R02<br><br>Objective: Verify that terminating a workforce member in Microsoft Entra ID automatically revokes their Keycloak access and prevents access to the Mock EHR application.<br><br>Test 1 – Account deprovisioning: Disable a synthetic employee account in Entra ID. Verify that the corresponding Keycloak account is automatically disabled within the organization's | Technical | akchrao@gmail.com | - | 5. Establish Termination Procedures |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | defined termination SLA.<br><br>Test 2 – Session revocation: Confirm that active Keycloak sessions are terminated or invalidated and that the terminated employee cannot reuse an existing application session.<br><br>Test 3 – Access verification: Attempt to authenticate and access the Mock EHR using the terminated test account. Verify that access is denied.<br><br>Test 4 – Audit logging: Confirm that termination, account disablement, session revocation, and verification activities are logged with timestamps.<br><br>Test 5 – Monitoring: Confirm that reconciliation or alerting identifies accounts that remain enabled after termination.<br><br>Acceptance criteria: All five tests must pass, with supporting screenshots and log evidence. Any failure requires corrective action and retesting.<br><br>Related finding: CAN-FIND-001<br>Related risk: R02<br>Status: Planned – Implementation and validation pending. | | | | |
| Vendor access is sponsored, time-boxed and removed at expiry | Vendor access is sponsored, time-boxed and removed at expiry<br><br>Area: Third-party access<br>HIPAA: 164.308(b)(1); 164.314(a)<br>NIST CSF 2.0: GV.SC-07, PR.AA-05<br>NIST SP 800-53 r5: AC-2(2), PS-7<br>ISO 27001:2022: A.5.19, A.5.20<br>PCI DSS 4.0.1: 8.2.7<br>Risks: R05<br>Evidence: Service/vendor identity register; TC-08<br>Test: TC-08<br>Test result (2026-11-03): PASS | Process | akchrao@gmail.com | - | 1. Identify Entities that are Business Associates Under the HIPAA Security Rule |

**Active (12)**

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| Security-relevant identity events are logged | Security-relevant identity events are logged | Technical | akchrao@gmail.com | - | 9. Implement the Information System Activity Review and Audit Process |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | Area: Monitoring<br>HIPAA: 164.312(b)<br>NIST CSF 2.0: DE.CM-03, PR.PS-04<br>NIST SP 800-53 r5: AU-2, AU-3, AU-12<br>ISO 27001:2022: A.8.15<br>PCI DSS 4.0.1: 10.2.1<br>Risks: R03, R04<br>Evidence: keycloak_login_events.csv; Wazuh (IR lab)<br>Test: W5 detect run<br>Test result (2026-11-03): PASS | | | | 1. Determine the Activities that Will Be Tracked or Audited |
| Lockout after repeated failures; strong password standard | Lockout after repeated failures; strong password standard<br><br>Area: Authentication<br>HIPAA: 164.308(a)(5)(ii)(D)<br>NIST CSF 2.0: PR.AA-03<br>NIST SP 800-53 r5: AC-7, IA-5(1)<br>ISO 27001:2022: A.5.17, A.8.5<br>PCI DSS 4.0.1: 8.3.4, 8.3.6, 8.3.7<br>Risks: R03<br>Evidence: EV-13 lockout + password tests<br>Test: W5 verify; TC-05<br>Test result (2026-11-03): PASS | Technical | akchrao@gmail.com | - | Implementation Specification (Log-in Monitoring)<br>Implementation Specification (Password Management)<br>3. Select and Implement Authentication Options |
| Security risks are identified, scored and treated | Security risks are identified, scored and treated<br><br>Area: GRC<br>HIPAA: 164.308(a)(1)(ii)(A)-(B)<br>NIST CSF 2.0: ID.RA-05, ID.RA-06<br>NIST SP 800-53 r5: RA-3, PM-9<br>ISO 27001:2022: Clause 6.1.2, 6.1.3<br>PCI DSS 4.0.1: 12.3.1<br>Risks: R01-R05<br>Evidence: Risk register R01-R05 (Risk Management 1)<br>Test: Register review<br>Test result (2026-11-03): PASS | Process | akchrao@gmail.com | - | 2. Conduct Risk Assessment<br>3. Implement a Risk Management Program |
| Users receive only the access their job requires (RBAC, least privilege) | Users receive only the access their job requires (RBAC, least privilege)<br><br>Area: IAM / RBAC<br>HIPAA: 164.308(a)(4)(ii)(B); 164.312(a)(1)<br>NIST CSF 2.0: PR.AA-05<br>NIST SP 800-53 r5: AC-2, AC-3, AC-6<br>ISO 27001:2022: A.5.15, A.5.18<br>PCI DSS 4.0.1: 7.2.1, 7.2.2 | Technical | akchrao@gmail.com | - | 2. Implement Policies and Procedures for Authorizing Access<br>3. Implement Policies and Procedures for Access Establishment and Modification<br>1. Analyze Workloads and Operations to Identify the Access Needs of All Users<br>3. Ensure that All System Users Have Been Assigned a Unique Identifier |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | Risks: R01<br>Evidence: EV-13 access reviews; TC-01<br>Test: TC-01; audit AC-01 tests 1-2<br>Test result (2026-11-03): PASS | | | | 5. Implement Access Control Procedures Using Selected Hardware and Software |
| Terminated users are disabled and all access removed promptly | Terminated users are disabled and all access removed promptly<br><br>Area: IAM / JML<br>HIPAA: 164.308(a)(3)(ii)(C)<br>NIST CSF 2.0: PR.AA-01, PR.AA-05<br>NIST SP 800-53 r5: AC-2, PS-4<br>ISO 27001:2022: A.5.18, A.6.5<br>PCI DSS 4.0.1: 8.2.5<br>Risks: R02<br>Evidence: JML evidence (TERM-2026-0301); TC-04; TC-09<br>Test: TC-04; TC-09<br>Test result (2026-11-03): PASS (after CA-09) | Technical | akchrao@gmail.com | - | 5. Establish Termination Procedures<br>9. Terminate Access if it is No Longer Required |
| Workforce Termination and Access Revocation | This control manages employee termination and access revocation across Microsoft Entra ID and Keycloak.<br><br>It includes disabling terminated employee accounts, revoking sessions, removing application roles, manually disabling federated Keycloak accounts, and verifying access removal.<br><br>Jeevan Smith's termination (TERM-2026-0301) demonstrated successful manual deprovisioning. However, automatic Keycloak account deactivation is not yet implemented, creating a residual IAM security risk. | Process | akchrao@gmail.com | - | 5. Establish Termination Procedures |
| Alerts are raised and investigated | Alerts are raised and investigated<br><br>Area: Monitoring / IR<br>HIPAA: 164.308(a)(1)(ii)(D); 164.308(a)(6)(ii)<br>NIST CSF 2.0: DE.AE-02, DE.AE-06<br>NIST SP 800-53 r5: AU-6, SI-4<br>ISO 27001:2022: A.8.16<br>PCI DSS 4.0.1: 10.4.1<br>Risks: R03, R04<br>Evidence: identity_detections.csv; IR1 Tasks 2-3<br>Test: TC-05, TC-06, TC-07<br>Test result (2026-11-03): PASS (TC-05 after CA-10) | Technical | akchrao@gmail.com | - | 7. Develop and Deploy the Information System Activity Review Process<br>9. Implement the Information System Activity Review and Audit Process Implementation Specification (Log-in Monitoring)<br>5. Implement the Audit/System Activity Review Process |
| Access is reviewed periodically and findings are remediated | Access is reviewed periodically and findings are remediated<br><br>Area: IAM / GRC<br>HIPAA: 164.308(a)(4)(ii)(C); 164.308(a)(1)(ii)(D) | Process | akchrao@gmail.com | - | 7. Develop and Deploy the Information System Activity Review Process<br>4. Evaluate Existing Security Measures Related to Access Controls |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | NIST CSF 2.0: PR.AA-05, ID.IM-01<br>NIST SP 800-53 r5: AC-2(j)<br>ISO 27001:2022: A.5.18<br>PCI DSS 4.0.1: 7.2.4, 7.2.5.1<br>Risks: R01, R02<br>Evidence: access_review_*.csv; TC-09; AR-2026-Q4 signed 2026-11-09<br>Test: TC-09; AR-2026-Q4 sign-off<br>Test result (2026-11-03): PASS | | | | 6. Review and Update Access for Users and Processes |
| Control gaps are tracked to verified remediation | Control gaps are tracked to verified remediation<br><br>Area: GRC<br>HIPAA: 164.308(a)(8)<br>NIST CSF 2.0: ID.IM-01, GV.OV-03<br>NIST SP 800-53 r5: CA-5, CA-7<br>ISO 27001:2022: Clause 10.2<br>PCI DSS 4.0.1: 12.4.2<br>Risks: R01-R05<br>Evidence: Corrective action tracker; exception register<br>Test: TC-10<br>Test result (2026-11-03): PASS | Process | akchrao@gmail.com | - | 3. Implement a Risk Management Program<br>3. Conduct Evaluation |
| Incidents are handled with a tested playbook | Incidents are handled with a tested playbook<br><br>Area: Incident response<br>HIPAA: 164.308(a)(6)(i)-(ii)<br>NIST CSF 2.0: RS.MA-01, RS.AN-03<br>NIST SP 800-53 r5: IR-4, IR-5, IR-8<br>ISO 27001:2022: A.5.24-A.5.28<br>PCI DSS 4.0.1: 12.10.1<br>Risks: R03, R04<br>Evidence: IR1 Tasks 1-6; CAN-IR-PB-02<br>Test: IR1 Task 6 (34 checks)<br>Test result (2026-11-03): PASS | Process | akchrao@gmail.com | - | 3. Develop and Implement Policy and Procedures to Respond to and Report Security Incidents<br>4. Incorporate Post-Incident Analysis into Updates and Revisions |
| Role changes remove old access before new access is granted | Role changes remove old access before new access is granted<br><br>Area: IAM / JML<br>HIPAA: 164.308(a)(4)(ii)(C)<br>NIST CSF 2.0: PR.AA-05<br>NIST SP 800-53 r5: AC-2, PS-5<br>ISO 27001:2022: A.5.18<br>PCI DSS 4.0.1: 7.2.4<br>Risks: R01<br>Evidence: JML evidence (CHG-2026-0201); TC-03 | Technical | akchrao@gmail.com | - | 3. Implement Policies and Procedures for Access Establishment and Modification |

| Name | Description | Category | Owner | ETA | Matching items |
|---|---|---|---|---|---|
| | Test: TC-03<br>Test result (2026-11-03): PASS | | | | |
| Each application admits only approved job roles | Each application admits only approved job roles<br><br>Area: IAM / application access<br>HIPAA: 164.312(a)(1)<br>NIST CSF 2.0: PR.AA-05<br>NIST SP 800-53 r5: AC-3<br>ISO 27001:2022: A.8.3<br>PCI DSS 4.0.1: 7.2.1<br>Risks: R01<br>Evidence: EV-13 app-gate verify; TC-02<br>Test: TC-02<br>Test result (2026-11-03): PASS | Technical | akchrao@gmail.com | - | 5. Implement Access Control Procedures Using Selected Hardware and Software |

Generated at 2026-11-09 17:33:18 UTC
Document ID 919117ba-6b58-4823-ad57-f7a45174e4df